

BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC ĐẠI NAM



BÀI TẬP LỚN

TÊN HỌC PHẦN: NHẬP MÔN AN TOÀN VÀ BẢO MẬT THÔNG TIN
ĐỀ 18: ỨNG DỤNG BẢO MẬT TIN NHẮN VĂN BẢN VỚI MÃ HÓA DES
VÀ XÁC THỰC RSA

Giảng viên hướng dẫn: ThS. Lê Thị Thùy Trang

Sinh viên thực hiện:

STT	Mã SV	Họ và tên	Lớp
1	1871020062	Phạm Phương Anh	CNTT 18-02
2	1871020579	Dương Thị Huyền Trang	CNTT 18-02
3	1871020615	Phạm Anh Tú	CNTT 18-02
4	1871020313	Nguyễn Văn Huy	CNTT 18-02

Hà Nội, năm 2026

BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC ĐẠI NAM



BÀI TẬP LỚN

TÊN HỌC PHẦN: NHẬP MÔN AN TOÀN VÀ BẢO MẬT THÔNG TIN
ĐỀ 18: ỨNG DỤNG BẢO MẬT TIN NHẮN VĂN BẢN VỚI MÃ HÓA DES
VÀ XÁC THỰC RSA

STT	Mã Sinh Viên	Họ và tên	Ngày sinh	Điểm	Ghi chú
1	1871020062	Phạm Phương Anh	08/01/2006		
2	1871020579	Dương Thị Huyền Trang	29/01/2006		
3	1871020615	Phạm Anh Tú	22/07/2006		
4	1871020313	Nguyễn Văn Huy	03/07/2004		

CÁN BỘ CHẤM THI

Hà Nội, năm 2026

LỜI CAM ĐOAN

Nhóm chúng em xin cam đoan báo cáo với đề tài “**Legacy DES Attack and Migration Chat – Ứng dụng bảo mật tin nhắn văn bản với mã hóa DES và xác thực RSA**” là kết quả nghiên cứu, tìm hiểu và thực hiện của chính nhóm trong quá trình học tập và thực hiện học phần An toàn và Bảo mật Thông tin.

Toàn bộ nội dung, kết quả nghiên cứu, chương trình và các hình ảnh minh họa được trình bày trong báo cáo là trung thực, được thực hiện trên cơ sở tìm hiểu các tài liệu khoa học, tài liệu chính thức và các chuẩn mật mã hiện đại. Những tài liệu tham khảo từ các nguồn khác đều đã được nhóm trích dẫn đầy đủ trong phần tài liệu tham khảo.

Nhóm xin chịu hoàn toàn trách nhiệm về tính trung thực, tính chính xác của nội dung báo cáo cũng như kết quả đạt được trong quá trình thực hiện đề tài.

Hà Nội, ngày 07 tháng 02 năm 2026

LỜI CẢM ƠN

Nhóm chúng em xin bày tỏ lòng biết ơn sâu sắc tới Ban Giám hiệu Trường Đại học Đại Nam, Khoa Công nghệ Thông tin cùng toàn thể quý thầy cô đã tận tình giảng dạy, truyền đạt những kiến thức chuyên môn và tạo điều kiện thuận lợi để nhóm hoàn thành học phần **An toàn và Bảo mật Thông tin**.

Đặc biệt, nhóm xin gửi lời cảm ơn chân thành tới giảng viên hướng dẫn đã tận tình hướng dẫn, góp ý và hỗ trợ nhóm trong suốt quá trình thực hiện đề tài **“Legacy DES Attack and Migration Chat – Ứng dụng bảo mật tin nhắn văn bản với mã hóa DES và xác thực RSA”**. Những ý kiến đóng góp quý báu của thầy/cô đã giúp nhóm hoàn thiện cả về nội dung nghiên cứu lẫn quá trình xây dựng chương trình.

Trong quá trình thực hiện đề tài, nhóm đã có cơ hội vận dụng các kiến thức về mật mã học, bảo mật hệ thống, lập trình mạng và phát triển phần mềm để xây dựng một ứng dụng nhắn tin an toàn, đồng thời nghiên cứu quá trình chuyển đổi từ hệ thống mã hóa DES truyền thống sang các cơ chế bảo mật hiện đại như AES-GCM kết hợp xác thực bằng RSA.

Mặc dù nhóm đã cố gắng hoàn thành đề tài với tinh thần nghiêm túc và trách nhiệm cao, song do thời gian thực hiện cũng như kiến thức và kinh nghiệm còn hạn chế nên báo cáo không tránh khỏi những thiếu sót. Nhóm rất mong nhận được những ý kiến đóng góp và nhận xét từ quý thầy cô để báo cáo được hoàn thiện hơn.

Nhóm xin chân thành cảm ơn!

Hà Nội, ngày 07 tháng 02 năm 2026

KÍ HIỆU CÁC CỤM TỪ VIẾT TẮT

TỪ VIẾT TẮT	TÊN ĐẦY ĐỦ CỦA TỪ VIẾT TẮT
AES	Advanced Encryption Standard
GCM	Galois Counter Mode
DES	Data Encryption Standard
RSA	Rivest–Shamir–Adleman
RSA-OAEP	RSA Optimal Asymmetric Encryption Padding
RSA-PSS	RSA Probabilistic Signature Scheme
HKDF	HMAC-based Key Derivation Function
AEAD	Authenticated Encryption with Associated Data
SHA-256	Secure Hash Algorithm 256-bit
UUID	Universally Unique Identifier
API	Application Programming Interface
UI	User Interface
TCP	Transmission Control Protocol
JSON	JavaScript Object Notation
UTF-8	Unicode Transformation Format - 8 bit

DANH MỤC CÁC BẢNG, SƠ ĐỒ, HÌNH

BẢNG:

Tên bảng	Trang
Bảng 2.1. Module hệ thống	15
Bảng 3.1. Môi trường triển khai hệ thống.....	17
Bảng 3.2. Kết quả kiểm thử các chức năng của hệ thống	25
Bảng 3.3. So sánh giữa hệ thống Legacy và hệ thống sau nâng cấp.....	28

SƠ ĐỒ:

Tên sơ đồ	Trang
Sơ đồ 1.1. Kiến trúc tổng thể của hệ thống	7

HÌNH:

Tên hình	Trang
Hình 2.1. Kiến trúc tổng thể hệ thống	10
Hình 2.2. Kiến trúc tổng thể của hệ thống	13
Hình 2.3. Luồng thiết lập phiên bảo mật.....	14
Hình 2.4. Sequence Diagram của quá trình thiết lập phiên bảo mật	15
Hình 3.1. Trang chủ của hệ thống Secure Message Server.....	21
Hình 3.2. Giao diện phía Client	21
Hình 3.3. Giao diện thông tin bảo mật	22
Hình 3.4. Giao diện gửi tin nhắn	23
Hình 3.5. Giao diện nhận tin nhắn	23
Hình 3.6. Giao diện quản lý tin nhắn.....	24
Hình 3.7. Giao diện nhật ký hoạt động của hệ thống	24

MỤC LỤC

LỜI CAM ĐOAN	i
LỜI CẢM ƠN	ii
KÍ HIỆU CÁC CỤM TỪ VIẾT TẮT	iii
DANH MỤC CÁC BẢNG, SƠ ĐỒ, HÌNH	iv
LỜI MỞ ĐẦU	viii
CHƯƠNG 1. GIỚI THIỆU ĐỀ TÀI	1
1.1. Lý do chọn đề tài	2
1.2. Mục tiêu của đề tài	2
1.3. Phạm vi nghiên cứu	3
1.4. Phương pháp nghiên cứu	4
1.5. Công nghệ sử dụng	5
1.5.1. Ngôn ngữ lập trình Python	5
1.5.2. Framework Flask	5
1.5.3. Socket TCP	5
1.5.4. Thuật toán DES và RSA	5
1.5.5. Thư viện Cryptography	6
1.5.6. Git và GitHub	6
1.6. Kiến trúc tổng thể của hệ thống	6
1.7. Các chức năng chính của hệ thống	7
1.8. Yêu cầu chức năng	8
1.9. Yêu cầu phi chức năng	8
1.10. Kết luận chương	9
CHƯƠNG 2. PHÂN TÍCH VÀ THIẾT KẾ HỆ THỐNG	10
2.1. Phân tích yêu cầu hệ thống	10
2.2. Kiến trúc hệ thống	10
2.3. Thiết kế các module	11
2.3.1. Module Client	11
2.3.2. Module Server	11
2.3.3. Module Crypto	11
2.3.4. Module RSA-PSS	11
2.3.5. Module Key Management	12
2.3.6. Module Session Management	12

2.4. Quy trình hoạt động	12
2.5. Sơ đồ kiến trúc hệ thống	13
2.6. Flow hoạt động	14
2.7. Sequence Diagram	15
2.8. Bảng module	15
2.9. Kết luận chương	15
CHƯƠNG 3. TRIỂN KHAI VÀ ĐÁNH GIÁ HỆ THỐNG	17
3.1. Môi trường triển khai hệ thống	17
3.2. Kiến trúc hệ thống sau khi nâng cấp	18
3.3. Triển khai các chức năng nâng cấp	18
3.3.1. <i>Nâng cấp giao diện hệ thống</i>	19
3.3.2. <i>Nâng cấp thuật toán mã hóa</i>	19
3.3.3. <i>Nâng cấp cơ chế xác thực</i>	19
3.3.4. <i>Nâng cấp quản lý khóa</i>	19
3.3.5. <i>Nâng cấp cơ chế chống Replay Attack</i>	20
3.3.6. <i>Nâng cấp cơ chế ghi nhật ký</i>	20
3.4. Giao diện hệ thống sau khi nâng cấp	20
3.4.1. <i>Trang chủ hệ thống</i>	20
3.4.2. <i>Giao diện Client</i>	21
3.4.3. <i>Trang bảo mật</i>	22
3.4.4. <i>Giao diện gửi tin nhắn</i>	22
3.4.5. <i>Giao diện nhận tin nhắn</i>	23
3.4.6. <i>Giao diện quản lý tin nhắn</i>	23
3.4.7. <i>Giao diện nhật ký hoạt động</i>	24
3.5. Kết quả kiểm thử hệ thống	25
3.6. Đánh giá các cơ chế bảo mật sau khi nâng cấp	25
3.6.1. <i>Đánh giá thuật toán mã hóa</i>	26
3.6.2. <i>Đánh giá cơ chế trao đổi khóa</i>	26
3.6.3. <i>Đánh giá cơ chế xác thực</i>	26
3.6.4. <i>Đánh giá cơ chế kiểm tra toàn vẹn</i>	26
3.6.5. <i>Đánh giá cơ chế chống Replay Attack</i>	27
3.6.6. <i>Đánh giá cơ chế ghi nhật ký</i>	27
3.7. So sánh hệ thống Legacy và hệ thống sau nâng cấp	28
3.8. Đánh giá chung	28
3.9. Kết luận chương	29
KẾT LUẬN	30

PHỤ LỤC	32
TÀI LIỆU THAM KHẢO	36

LỜI MỞ ĐẦU

Trong thời đại công nghệ số, việc trao đổi thông tin thông qua Internet đã trở thành nhu cầu thiết yếu trong học tập, công việc và đời sống hằng ngày. Bên cạnh những lợi ích mà các hệ thống truyền thông trực tuyến mang lại, vấn đề bảo mật thông tin cũng ngày càng được quan tâm do các nguy cơ như nghe lén, giả mạo, sửa đổi hoặc đánh cắp dữ liệu trong quá trình truyền tải. Vì vậy, việc nghiên cứu và áp dụng các thuật toán mật mã nhằm bảo vệ tính bí mật, tính toàn vẹn và tính xác thực của dữ liệu là yêu cầu quan trọng đối với các hệ thống truyền thông hiện đại.

Trong lịch sử phát triển của mật mã học, thuật toán DES (Data Encryption Standard) từng được sử dụng rộng rãi trong nhiều hệ thống bảo mật. Tuy nhiên, với sự phát triển mạnh mẽ của năng lực tính toán, DES không còn đáp ứng được các yêu cầu an toàn thông tin hiện nay do kích thước khóa nhỏ và tồn tại nhiều nguy cơ bị tấn công vét cạn. Vì vậy, các hệ thống sử dụng DES cần được nâng cấp sang các cơ chế mã hóa hiện đại có mức độ an toàn cao hơn như AES-GCM hoặc ChaCha20-Poly1305.

Xuất phát từ thực tế đó, nhóm lựa chọn thực hiện đề tài **“Legacy DES Attack and Migration Chat – Ứng dụng bảo mật tin nhắn văn bản với mã hóa DES và xác thực RSA”**. Đề tài tập trung xây dựng một hệ thống nhắn tin mô phỏng quá trình chuyển đổi từ cơ chế bảo mật truyền thống sang cơ chế bảo mật hiện đại. Hệ thống không chỉ hỗ trợ mô phỏng chế độ DES Legacy nhằm minh họa những hạn chế của thuật toán DES mà còn triển khai cơ chế mã hóa hiện đại kết hợp xác thực bằng RSA nhằm nâng cao tính bảo mật trong quá trình trao đổi thông tin.

Trong quá trình thực hiện, nhóm tiến hành nghiên cứu các thuật toán mật mã đối xứng và bất đối xứng, cơ chế trao đổi khóa, chữ ký số, phương pháp xác thực và các kỹ thuật bảo vệ dữ liệu trong quá trình truyền tin. Đồng thời, nhóm thực hiện đánh giá, so sánh giữa DES và cơ chế mã hóa hiện đại về kích thước khóa, mức độ an toàn, hiệu năng xử lý và khả năng chống lại các hình thức tấn công phổ biến đối với hệ thống truyền thông.

Thông qua đề tài này, nhóm mong muốn vận dụng những kiến thức đã học trong học phần An toàn và Bảo mật Thông tin vào việc xây dựng một ứng dụng thực tế, đồng thời hiểu rõ hơn về quá trình nâng cấp các hệ thống bảo mật Legacy cũng như vai trò của các thuật toán mã hóa hiện đại trong việc bảo vệ dữ liệu trước các nguy cơ tấn công trên môi trường mạng.

Mặc dù nhóm đã nỗ lực hoàn thành đề tài trong phạm vi thời gian và kiến thức cho phép, báo cáo vẫn khó tránh khỏi những thiếu sót. Nhóm rất mong nhận được những ý kiến đóng góp của quý thầy cô để tiếp tục hoàn thiện đề tài trong thời gian tới.

CHƯƠNG 1. GIỚI THIỆU ĐỀ TÀI

Trong thời đại chuyển đổi số hiện nay, công nghệ thông tin đã trở thành nền tảng quan trọng trong mọi lĩnh vực của đời sống xã hội. Các hoạt động như trao đổi thông tin, giao dịch tài chính, học tập trực tuyến, thương mại điện tử hay quản lý doanh nghiệp đều phụ thuộc rất lớn vào hệ thống mạng máy tính và Internet. Nhờ sự phát triển mạnh mẽ của hạ tầng mạng cùng các công nghệ truyền thông hiện đại, việc chia sẻ dữ liệu giữa các cá nhân và tổ chức trở nên nhanh chóng, thuận tiện và hiệu quả hơn bao giờ hết.

Tuy nhiên, song song với những lợi ích đó là sự gia tăng nhanh chóng của các mối đe dọa về an toàn thông tin. Các cuộc tấn công mạng ngày càng tinh vi với nhiều hình thức khác nhau như nghe lén dữ liệu (Eavesdropping), giả mạo danh tính (Spoofing), thay đổi nội dung thông điệp (Tampering), tấn công trung gian (Man-in-the-Middle), tấn công phát lại (Replay Attack) hay đánh cắp khóa mã hóa. Những cuộc tấn công này có thể làm rò rỉ thông tin cá nhân, gây thất thoát dữ liệu quan trọng, ảnh hưởng đến uy tín của tổ chức cũng như gây thiệt hại lớn về kinh tế.

Để giảm thiểu các nguy cơ trên, việc nghiên cứu và áp dụng các giải pháp bảo mật hiện đại là yêu cầu cấp thiết đối với mọi hệ thống truyền thông. Các kỹ thuật mật mã hiện đại như mã hóa đối xứng, mã hóa bất đối xứng, chữ ký số, dẫn xuất khóa hay xác thực thông điệp đã trở thành nền tảng trong việc xây dựng các hệ thống thông tin an toàn.

Xuất phát từ thực tế đó, nhóm thực hiện lựa chọn đề tài "Secure System Upgrade" nhằm nghiên cứu, thiết kế và xây dựng một hệ thống truyền tin nhấn bảo mật ứng dụng các thuật toán mật mã hiện đại. Hệ thống được phát triển bằng ngôn ngữ lập trình Python theo mô hình Client – Server, kết hợp Framework Flask và giao thức Socket TCP để xây dựng môi trường truyền thông. Bên cạnh đó, hệ thống còn tích hợp các thuật toán AES-256-GCM, RSA, RSA-PSS, HKDF cùng cơ chế chống Replay Attack nhằm đảm bảo tính bí mật, tính toàn vẹn và tính xác thực của dữ liệu trong quá trình trao đổi.

Thông qua quá trình thực hiện đề tài, nhóm không chỉ vận dụng các kiến thức đã học trong học phần An toàn và Bảo mật Thông tin mà còn có cơ hội tiếp cận với các công nghệ bảo mật đang được áp dụng rộng rãi trong các hệ thống thực tế hiện nay. Kết quả của đề tài góp phần minh họa rõ ràng quy trình xây dựng một hệ thống truyền thông an toàn từ giai đoạn thiết kế kiến trúc đến triển khai các cơ chế bảo mật và đánh giá hiệu quả hoạt động của hệ thống.

1.1 Lý do chọn đề tài

Hiện nay, cùng với sự phát triển mạnh mẽ của Internet và các hệ thống thông tin, khối lượng dữ liệu được trao đổi qua mạng ngày càng lớn. Những dữ liệu này bao gồm thông tin cá nhân, dữ liệu tài chính, hồ sơ y tế, tài liệu doanh nghiệp cũng như nhiều loại thông tin quan trọng khác. Nếu không được bảo vệ đúng cách, các dữ liệu này có thể trở thành mục tiêu của các cuộc tấn công mạng.

Theo nhiều báo cáo về an toàn thông tin trong những năm gần đây, số lượng các vụ tấn công mạng có xu hướng gia tăng cả về quy mô lẫn mức độ phức tạp. Kẻ tấn công không chỉ khai thác các lỗ hổng trong hệ thống mà còn sử dụng nhiều kỹ thuật tinh vi để đánh cắp hoặc thay đổi dữ liệu trong quá trình truyền tải. Điều này đặt ra yêu cầu cấp thiết phải xây dựng các hệ thống truyền thông có khả năng bảo vệ dữ liệu một cách toàn diện.

Bên cạnh đó, nhiều ứng dụng hiện nay vẫn còn tồn tại các điểm yếu trong quá trình trao đổi thông tin như sử dụng thuật toán mã hóa không còn an toàn, thiếu cơ chế xác thực người gửi, không kiểm tra tính toàn vẹn dữ liệu hoặc chưa có biện pháp ngăn chặn các cuộc tấn công Replay Attack. Đây là nguyên nhân dẫn đến nguy cơ mất an toàn thông tin trong quá trình vận hành.

Xuất phát từ những vấn đề trên, nhóm lựa chọn đề tài xây dựng hệ thống Secure System Upgrade với mục tiêu nghiên cứu và triển khai một mô hình truyền tin bảo mật sử dụng đồng thời nhiều cơ chế bảo vệ khác nhau. Hệ thống không chỉ giúp bảo vệ dữ liệu khỏi các hình thức nghe lén mà còn đảm bảo khả năng xác thực, chống sửa đổi nội dung và ngăn chặn các cuộc tấn công phát lại.

Ngoài ý nghĩa thực tiễn, đề tài còn tạo điều kiện để nhóm vận dụng các kiến thức đã học về mật mã học, lập trình mạng, lập trình Python và các thư viện bảo mật hiện đại vào quá trình xây dựng một hệ thống hoàn chỉnh. Đây cũng là cơ hội để nhóm nâng cao kỹ năng phân tích, thiết kế và triển khai các giải pháp bảo mật trong môi trường thực tế.

1.2 Mục tiêu của đề tài

Mục tiêu của đề tài là nghiên cứu, thiết kế và xây dựng một hệ thống truyền tin nhấn bảo mật dựa trên các thuật toán mật mã hiện đại nhằm đảm bảo tính bí mật, tính toàn vẹn và tính xác thực của dữ liệu trong quá trình truyền tải qua mạng. Bên cạnh đó, hệ thống còn hướng tới khả năng ngăn chặn các hình thức tấn công phổ biến như Replay Attack, giả mạo danh tính và sửa đổi thông điệp.

Để đạt được mục tiêu tổng quát trên, nhóm thực hiện đã đề ra các mục tiêu cụ thể như sau:

- Nghiên cứu các nguyên lý cơ bản của mật mã học và an toàn thông tin.
- Tìm hiểu cơ chế hoạt động của các thuật toán mã hóa đối xứng và mã hóa bất đối xứng.
- Thiết kế mô hình truyền thông theo kiến trúc Client – Server.
- Xây dựng cơ chế trao đổi khóa an toàn giữa Client và Server.
- Áp dụng thuật toán AES-256-GCM để mã hóa và giải mã dữ liệu.
- Sử dụng thuật toán RSA để quản lý khóa công khai và khóa bí mật.
- Tích hợp chữ ký số RSA-PSS nhằm xác thực người gửi và đảm bảo tính toàn vẹn của thông điệp.
- Áp dụng thuật toán HKDF để sinh khóa phiên phục vụ quá trình mã hóa dữ liệu.
- Xây dựng cơ chế chống Replay Attack nhằm ngăn chặn việc phát lại các thông điệp cũ.
- Thực hiện kiểm thử hệ thống và đánh giá mức độ an toàn của các cơ chế bảo mật đã triển khai.

Việc hoàn thành các mục tiêu trên không chỉ giúp xây dựng được một hệ thống truyền thông bảo mật hoàn chỉnh mà còn giúp nhóm hiểu rõ quy trình thiết kế, triển khai và đánh giá một hệ thống an toàn thông tin trong thực tế.

1.3 Phạm vi nghiên cứu

Trong khuôn khổ của học phần An toàn và Bảo mật Thông tin, đề tài tập trung nghiên cứu và triển khai các kỹ thuật bảo mật phục vụ cho việc trao đổi dữ liệu giữa Client và Server thông qua môi trường mạng.

Đề tài tập trung xây dựng một hệ thống truyền tin nhắn văn bản có khả năng bảo vệ dữ liệu bằng nhiều lớp bảo mật khác nhau. Các nội dung nghiên cứu chính bao gồm:

- Thiết kế kiến trúc Client – Server.
- Xây dựng cơ chế trao đổi khóa giữa các thực thể.
- Quản lý khóa công khai và khóa bí mật.
- Sinh khóa phiên bằng thuật toán HKDF.

- Mã hóa và giải mã dữ liệu bằng AES-256-GCM.
- Tạo và xác minh chữ ký số RSA-PSS.
- Kiểm tra tính toàn vẹn của dữ liệu.
- Xây dựng cơ chế chống Replay Attack.
- Thực hiện kiểm thử các chức năng bảo mật.

Bên cạnh đó, đề tài cũng có một số giới hạn nhằm phù hợp với phạm vi của học phần. Hệ thống chưa triển khai các chức năng như lưu trữ dữ liệu trên cơ sở dữ liệu phân tán, tích hợp Blockchain, triển khai hạ tầng PKI hoàn chỉnh hoặc nghiên cứu các thuật toán mật mã hậu lượng tử. Những nội dung này sẽ là hướng phát triển trong tương lai nếu hệ thống được mở rộng.

1.4 Phương pháp nghiên cứu

Để hoàn thành đề tài, nhóm đã áp dụng kết hợp nhiều phương pháp nghiên cứu khác nhau nhằm đảm bảo tính khoa học cũng như khả năng triển khai thực tế của hệ thống.

Đầu tiên, nhóm tiến hành nghiên cứu lý thuyết về các nguyên lý cơ bản của an toàn thông tin, mật mã học, giao thức truyền thông mạng và các kỹ thuật xác thực dữ liệu. Các tài liệu được tham khảo từ sách chuyên ngành, tài liệu học thuật, tiêu chuẩn quốc tế và các tài liệu chính thức của thư viện Python Cryptography.

Sau khi hoàn thành quá trình nghiên cứu lý thuyết, nhóm tiến hành phân tích yêu cầu của hệ thống, xác định các chức năng cần xây dựng và thiết kế mô hình kiến trúc tổng thể. Từ đó, hệ thống được chia thành các module độc lập nhằm thuận tiện cho việc phát triển và kiểm thử.

Tiếp theo, nhóm sử dụng ngôn ngữ lập trình Python để hiện thực hệ thống. Framework Flask được sử dụng để xây dựng giao diện và xử lý các yêu cầu từ phía người dùng, trong khi Socket TCP đảm nhiệm chức năng truyền thông giữa Client và Server. Các thuật toán mật mã như AES-256-GCM, RSA, RSA-PSS và HKDF được tích hợp

trực tiếp vào quá trình trao đổi dữ liệu nhằm đảm bảo mọi thông điệp đều được bảo vệ trước khi truyền trên mạng.

Sau khi hoàn thiện hệ thống, nhóm tiến hành xây dựng nhiều kịch bản kiểm thử khác nhau nhằm đánh giá tính đúng đắn, hiệu năng cũng như khả năng chống chịu trước các hình thức tấn công phổ biến. Kết quả kiểm thử được tổng hợp và phân tích để đánh giá mức độ đáp ứng của hệ thống đối với các yêu cầu đã đề ra.

Thông qua quá trình nghiên cứu và triển khai, nhóm đã có cơ hội tiếp cận với các công nghệ bảo mật hiện đại, đồng thời nâng cao khả năng phân tích, thiết kế và phát triển các hệ thống an toàn thông tin trong môi trường thực tế.

1.5 Công nghệ sử dụng

Để xây dựng hệ thống Legacy DES Attack and Migration Chat, nhóm đã lựa chọn các công nghệ và thư viện phù hợp nhằm đáp ứng yêu cầu xây dựng một hệ thống truyền tin an toàn, dễ triển khai và có khả năng mở rộng trong tương lai. Việc lựa chọn các công nghệ này dựa trên tính ổn định, mức độ phổ biến cũng như khả năng hỗ trợ phát triển các ứng dụng bảo mật.

1.5.1 Ngôn ngữ lập trình Python

Python là ngôn ngữ lập trình chính được sử dụng trong toàn bộ dự án. Python có cú pháp đơn giản, dễ đọc và sở hữu hệ sinh thái thư viện phong phú, đặc biệt trong lĩnh vực lập trình mạng và an toàn thông tin.

Trong hệ thống, Python được sử dụng để xây dựng các module Client, Server, xử lý kết nối mạng, thực hiện mã hóa, giải mã và quản lý toàn bộ quá trình trao đổi dữ liệu.

1.5.2 Framework Flask

Flask là một Micro Web Framework được xây dựng trên nền tảng Python. Framework này được sử dụng để xây dựng giao diện tương tác với người dùng, tiếp nhận yêu cầu gửi tin nhắn và hiển thị kết quả xử lý của hệ thống.

Flask có ưu điểm nhẹ, dễ mở rộng và phù hợp với các ứng dụng vừa và nhỏ.

1.5.3 Socket TCP

Hệ thống sử dụng Socket TCP để thiết lập kết nối giữa Client và Server. TCP đảm bảo dữ liệu được truyền đầy đủ, đúng thứ tự và hạn chế mất gói tin trong quá trình truyền thông.

1.5.4 Thuật toán DES và RSA

DES được sử dụng để minh họa cơ chế mã hóa dữ liệu trong hệ thống cũ, đồng thời làm cơ sở để nghiên cứu quá trình nâng cấp lên các thuật toán bảo mật hiện đại hơn.

RSA được sử dụng để quản lý khóa công khai và khóa bí mật, hỗ trợ xác thực cũng như đảm bảo tính an toàn trong quá trình trao đổi dữ liệu.

1.5.5 Thư viện Cryptography

Thư viện Cryptography của Python được sử dụng để triển khai các thuật toán mật mã. Thư viện cung cấp đầy đủ các chức năng phục vụ sinh khóa, mã hóa, giải mã và xác thực dữ liệu theo các tiêu chuẩn hiện đại.

1.5.6 Git và GitHub

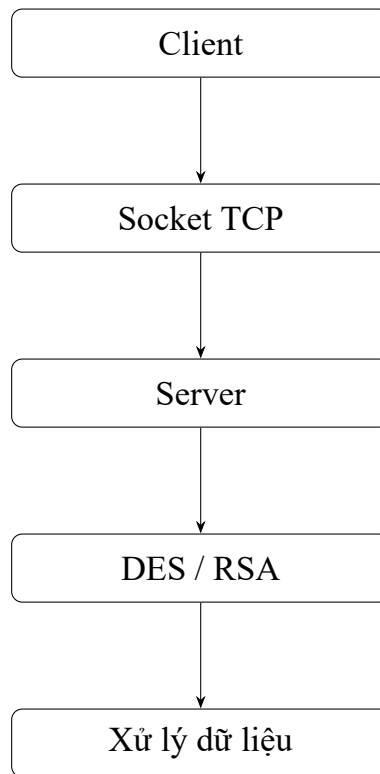
Git được sử dụng để quản lý phiên bản mã nguồn, trong khi GitHub hỗ trợ lưu trữ, chia sẻ và đồng bộ mã nguồn giữa các thành viên trong nhóm.

1.6 Kiến trúc tổng thể của hệ thống

Hệ thống được xây dựng theo mô hình Client – Server. Trong mô hình này, Client đóng vai trò gửi yêu cầu và nhập nội dung tin nhắn, còn Server tiếp nhận, xử lý và phản hồi dữ liệu. Toàn bộ dữ liệu trước khi truyền qua mạng đều được mã hóa nhằm đảm bảo tính bảo mật.

Quy trình hoạt động của hệ thống được thực hiện theo các bước sau:

1. Người dùng khởi động Server.
2. Client thiết lập kết nối tới Server thông qua Socket TCP.
3. Hai bên thực hiện trao đổi khóa RSA.
4. Nội dung tin nhắn được mã hóa bằng DES (hoặc thuật toán sau khi nâng cấp).
5. Dữ liệu được truyền đến Server.
6. Server tiến hành giải mã và kiểm tra dữ liệu.
7. Kết quả được gửi lại cho Client.



Sơ đồ 1.1. Kiến trúc tổng thể của hệ thống

Nguồn: Nhóm tác giả xây dựng

1.7 Các chức năng chính của hệ thống

Hệ thống được xây dựng với các chức năng chính sau:

- Khởi động Server và chờ kết nối từ Client.
- Thiết lập kết nối mạng thông qua giao thức TCP.
- Sinh và quản lý khóa RSA.
- Thực hiện mã hóa dữ liệu bằng DES.
- Giải mã dữ liệu tại phía nhận.
- Gửi và nhận tin nhắn giữa Client và Server.
- Kiểm tra tính hợp lệ của dữ liệu.
- Hiện thị kết quả trên giao diện người dùng.
- Ghi nhật ký hoạt động của hệ thống.

Các chức năng được tổ chức thành các module độc lập, giúp chương trình dễ bảo trì và thuận tiện cho việc mở rộng sau này.

1.8 Yêu cầu chức năng

Hệ thống cần đáp ứng các yêu cầu chức năng sau:

1. Cho phép Client kết nối tới Server.
2. Hỗ trợ gửi và nhận tin nhắn.
3. Mã hóa dữ liệu trước khi truyền.
4. Giải mã dữ liệu tại phía nhận.
5. Quản lý khóa RSA.
6. Kiểm tra tính toàn vẹn của dữ liệu.
7. Thông báo lỗi khi xảy ra mất kết nối.
8. Hiển thị kết quả gửi và nhận trên giao diện.
9. Cho phép nhiều lần trao đổi dữ liệu trong cùng một phiên làm việc.

1.9 Yêu cầu phi chức năng

Ngoài các chức năng chính, hệ thống cần đáp ứng các yêu cầu phi chức năng nhằm đảm bảo khả năng hoạt động ổn định và an toàn.

Tính bảo mật

Dữ liệu truyền trên mạng phải được mã hóa nhằm hạn chế nguy cơ bị nghe lén hoặc đánh cắp.

Hiệu năng

Quá trình mã hóa, giải mã và truyền dữ liệu phải được thực hiện nhanh chóng nhằm đảm bảo trải nghiệm của người sử dụng.

Khả năng mở rộng

Kiến trúc Client – Server cho phép mở rộng thêm nhiều Client hoặc bổ sung các chức năng mới mà không ảnh hưởng đến cấu trúc hiện tại.

Khả năng bảo trì

Mã nguồn được tổ chức thành các module độc lập giúp việc nâng cấp và sửa lỗi được thực hiện thuận lợi.

Khả năng tương thích

Hệ thống có thể hoạt động trên các hệ điều hành Windows, Linux và macOS khi đã cài đặt môi trường Python phù hợp.

1.10 Kết luận chương

Trong chương này, nhóm đã trình bày tổng quan về đề tài, lý do lựa chọn, mục tiêu, phạm vi nghiên cứu và phương pháp thực hiện. Đồng thời, chương cũng giới thiệu các công nghệ được sử dụng, kiến trúc tổng thể của hệ thống, các chức năng chính cùng những yêu cầu chức năng và phi chức năng cần đáp ứng.

Những nội dung trên là cơ sở để triển khai các bước phân tích, thiết kế và xây dựng hệ thống trong các chương tiếp theo. Trên nền tảng các yêu cầu đã xác định, Chương 2 sẽ tập trung phân tích kiến trúc chương trình, mô hình hoạt động, cấu trúc các module và nguyên lý triển khai các thuật toán bảo mật trong hệ thống.

CHƯƠNG 2. PHÂN TÍCH VÀ THIẾT KẾ HỆ THỐNG

2.1 Phân tích yêu cầu hệ thống

Hệ thống Secure Message System được xây dựng nhằm đảm bảo truyền tải tin nhắn an toàn với ba yếu tố:

- **Tính bảo mật (Confidentiality):** Dữ liệu mã hóa AES-256-GCM.
- **Tính toàn vẹn (Integrity):** Authentication Tag + RSA-PSS.
- **Tính xác thực (Authentication):** RSA-PSS xác thực hai chiều.
- **Chống Replay Attack:** Sử dụng msg_id duy nhất.

Ngoài ra hệ thống cần:

- Giao tiếp socket ổn định.
- Xử lý nhiều client.
- Ghi log hoạt động.
- Giao diện Flask.

2.2 Kiến trúc hệ thống

Hệ thống gồm 3 tầng:

- **Giao diện:** Flask Web UI
- **Xử lý:** Crypto + Business Logic
- **Truyền thông:** Socket TCP

Client → Socket Client → Internet → Socket Server → Server UI

Hình 2.1. Kiến trúc tổng thể hệ thống

2.3 Thiết kế các module

2.3.1 *Module Client*

File: `client_app.py`, `socket_client.py`

- Flask UI
- Socket client
- Mã hóa dữ liệu
- Handshake

2.3.2 *Module Server*

File: `server_app.py`, `socket_server.py`

- Quản lý client
- Giải mã dữ liệu
- Xác thực RSA-PSS
- Chống replay

2.3.3 *Module Crypto*

File: `crypto_utils.py`

- AES-256-GCM
- HKDF key
- Nonce 12 bytes

2.3.4 *Module RSA-PSS*

- SHA-256
- RSA 2048-bit
- PSS padding

2.3.5 Module Key Management

- RSA trao đổi khóa
- HKDF sinh AES key

2.3.6 Module Session Management

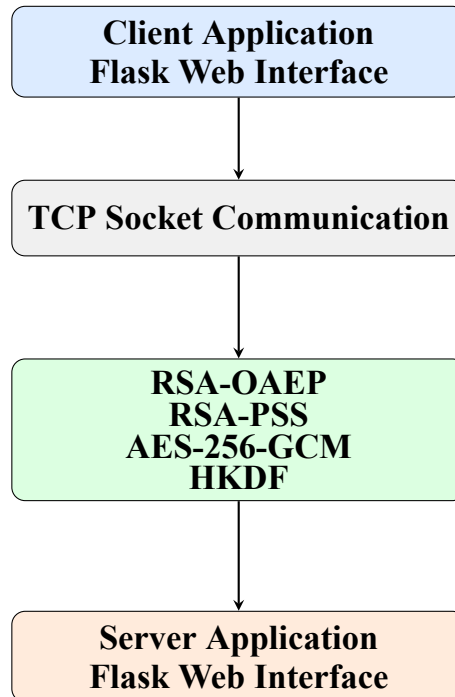
- Thiết lập Secure Session.
- Quản lý Session Key.
- Lưu trạng thái phiên làm việc.

2.4 Quy trình hoạt động

Quá trình thiết lập phiên bảo mật của hệ thống được thực hiện theo các bước sau:

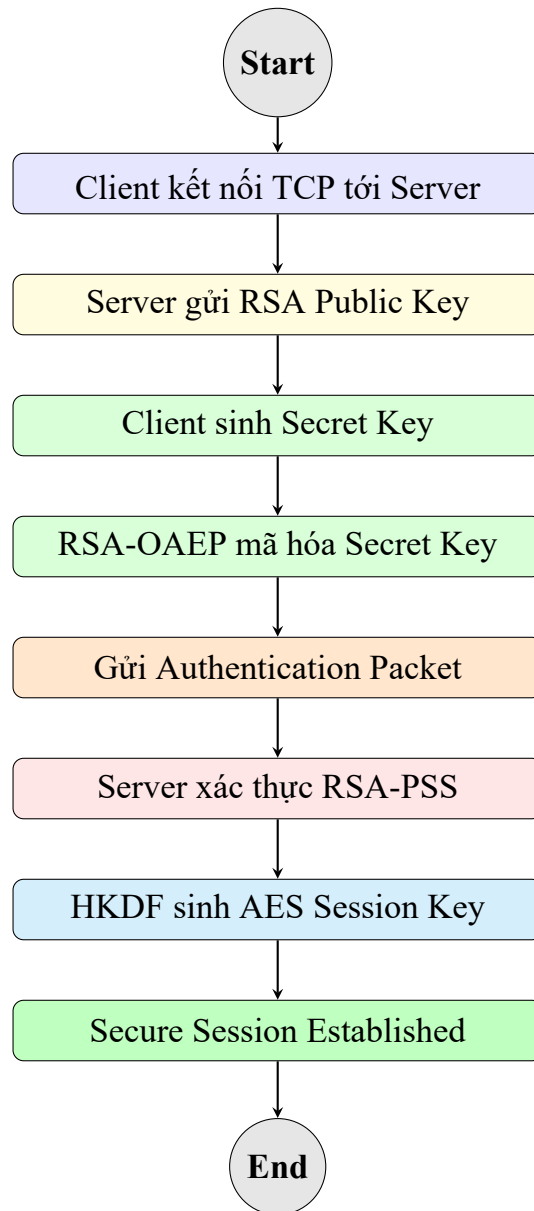
1. Client khởi tạo kết nối TCP đến Server.
2. Hai bên thực hiện quá trình Handshake.
3. Server gửi khóa công khai RSA cho Client.
4. Client sinh khóa bí mật ngẫu nhiên.
5. Khóa bí mật được mã hóa bằng RSA-OAEP.
6. Client gửi gói xác thực (Authentication Packet).
7. Server giải mã khóa bí mật.
8. Hai bên sử dụng HKDF để sinh khóa AES-256-GCM.
9. Client ký dữ liệu bằng RSA-PSS.
10. Server kiểm tra chữ ký số.
11. Nếu xác thực thành công, phiên bảo mật được thiết lập.

2.5 Sơ đồ kiến trúc hệ thống



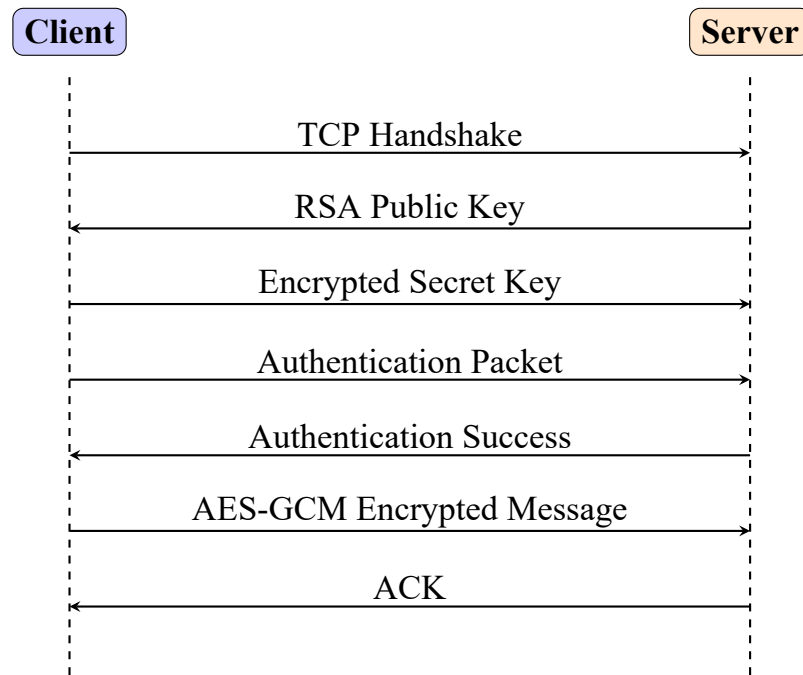
Hình 2.2. Kiến trúc tổng thể của hệ thống

2.6 Flow hoạt động



Hình 2.3. Luồng thiết lập phiên bảo mật

2.7 Sequence Diagram



Hình 2.4. Sequence Diagram của quá trình thiết lập phiên bảo mật

2.8 Bảng module

Module	Chức năng	File
Client	Gửi/nhận, mã hóa	client_app.py socket_client.py
Server	Giải mã, xác thực	server_app.py socket_server.py
Crypto	AES-GCM, HKDF	crypto_utils.py
Security	RSA-PSS, HKDF, Session	socket_server.py
Test	Benchmark	test_security.py

Bảng 2.1. Module hệ thống

2.9 Kết luận chương

Chương này đã trình bày quá trình phân tích yêu cầu và thiết kế hệ thống Secure Message System theo mô hình Client–Server.

Kiến trúc hệ thống bao gồm giao diện Web Flask, Socket TCP và các mô-đun mật mã. Quá trình thiết lập phiên bảo mật sử dụng RSA-OAEP để trao đổi khóa, HKDF để

sinh khóa phiên AES-256-GCM và RSA-PSS để xác thực Client trước khi thiết lập Secure Session.

Thiết kế này đáp ứng các yêu cầu về:

- Bảo mật khóa phiên.
- Xác thực Client và Server.
- Đảm bảo tính toàn vẹn dữ liệu xác thực.
- Thiết lập phiên liên lạc an toàn.

CHƯƠNG 3. TRIỂN KHAI VÀ ĐÁNH GIÁ HỆ THỐNG

3.1 Môi trường triển khai hệ thống

Sau khi hoàn thành quá trình phân tích, thiết kế và nâng cấp hệ thống truyền tin an toàn, nhóm tiến hành triển khai chương trình trên hệ điều hành Windows bằng ngôn ngữ lập trình Python. Hệ thống được xây dựng theo mô hình Client–Server, trong đó Client và Server giao tiếp với nhau thông qua giao thức TCP Socket, còn giao diện người dùng được phát triển dưới dạng ứng dụng Web bằng Flask.

So với hệ thống Legacy, phiên bản nâng cấp vẫn kế thừa kiến trúc tổng thể và giao diện Web nhằm đảm bảo tính ổn định và khả năng mở rộng. Tuy nhiên, các cơ chế bảo mật bên trong đã được thay thế bằng các thuật toán hiện đại hơn. Thuật toán DES được thay bằng AES-256-GCM, cơ chế trao đổi khóa sử dụng RSA-OAEP, chữ ký số sử dụng RSA-PSS và khóa phiên được dẫn xuất bằng HKDF. Ngoài ra, hệ thống còn bổ sung cơ chế phát hiện Replay Attack và ghi nhật ký hoạt động trên giao diện Web.

Bảng 3.1. Môi trường triển khai hệ thống

Thành phần	Thông tin
Hệ điều hành	Windows 11
Ngôn ngữ lập trình	Python 3.x
Framework Web	Flask
IDE	Visual Studio Code
Thư viện bảo mật	Cryptography
Giao thức truyền thông	TCP Socket
Thuật toán mã hóa	AES-256-GCM
Trao đổi khóa	RSA-OAEP
Xác thực chữ ký	RSA-PSS
Sinh khóa phiên	HKDF
Kiểm tra toàn vẹn	Authentication Tag (AES-GCM)
Chống Replay Attack	Message ID (Nonce)
Ghi nhật ký	Flask Logging và Web Logs

Qua quá trình triển khai thực tế, hệ thống hoạt động ổn định trên môi trường thử nghiệm. Hai ứng dụng Flask được khởi tạo tại cổng 5000 (Client) và 5001 (Server), đáp ứng yêu cầu truyền nhận dữ liệu theo thời gian thực.

3.2 Kiến trúc hệ thống sau khi nâng cấp

Hệ thống tiếp tục sử dụng mô hình Client–Server của phiên bản Legacy nhằm đảm bảo khả năng kế thừa và hạn chế việc thay đổi kiến trúc tổng thể. Trong mô hình này, Client chịu trách nhiệm gửi yêu cầu và dữ liệu đến Server thông qua kết nối TCP Socket, trong khi Server tiếp nhận, xác thực và xử lý các yêu cầu từ Client.

Khác với phiên bản cũ chỉ tập trung vào việc truyền dữ liệu, phiên bản nâng cấp bổ sung thêm nhiều cơ chế bảo mật nhằm đảm bảo tính bí mật, tính toàn vẹn và tính xác thực của thông tin trong quá trình truyền thông.

Các thành phần chính của hệ thống gồm:

- **Client Application:** Cung cấp giao diện Web cho người dùng, thực hiện kết nối tới Server, gửi và nhận dữ liệu đã được mã hóa.
- **Server Application:** Tiếp nhận yêu cầu từ Client, giải mã dữ liệu, xác thực chữ ký số và quản lý các phiên làm việc.
- **CryptoManager:** Thực hiện sinh khóa RSA, mã hóa và giải mã AES-256-GCM, tạo và xác minh chữ ký RSA-PSS, trao đổi khóa bằng RSA-OAEP và dẫn xuất khóa phiên bằng HKDF.
- **Socket Layer:** Thiết lập và duy trì kết nối TCP giữa Client và Server.
- **Logging Module:** Ghi lại toàn bộ các sự kiện trong quá trình hệ thống hoạt động để phục vụ kiểm thử và giám sát.

Nhờ giữ nguyên kiến trúc tổng thể nhưng thay đổi các thành phần xử lý bên trong, hệ thống vừa đảm bảo tính kế thừa vừa nâng cao đáng kể mức độ an toàn trong quá trình truyền dữ liệu.

3.3 Triển khai các chức năng nâng cấp

Dựa trên kết quả phân tích ở Chương 2, nhóm tiến hành kế thừa những thành phần còn phù hợp của hệ thống cũ và tập trung nâng cấp các cơ chế bảo mật. Việc nâng cấp không làm thay đổi kiến trúc tổng thể mà chủ yếu cải tiến các thuật toán mã hóa, cơ chế xác thực, quản lý khóa, kiểm tra toàn vẹn dữ liệu và khả năng ghi nhật ký.

3.3.1 Nâng cấp giao diện hệ thống

Phiên bản Legacy đã sử dụng Flask kết hợp HTML, CSS và JavaScript để xây dựng giao diện Web. Nhóm tiếp tục kế thừa kiến trúc này nhằm đảm bảo tính ổn định và thuận tiện trong việc phát triển.

Trên cơ sở đó, hệ thống được bổ sung các giao diện hiển thị trạng thái bảo mật, quản lý tin nhắn, nhật ký hoạt động, cảnh báo Replay Attack và kết quả xác thực chữ ký số nhằm hỗ trợ người dùng theo dõi quá trình truyền dữ liệu.

3.3.2 Nâng cấp thuật toán mã hóa

Trong hệ thống cũ, dữ liệu được mã hóa bằng DES hoặc Triple DES. Mặc dù đáp ứng yêu cầu truyền dữ liệu cơ bản nhưng các thuật toán này không còn đảm bảo mức độ an toàn trước các phương pháp tấn công hiện nay.

Phiên bản nâng cấp thay thế hoàn toàn DES bằng AES-256-GCM. Thuật toán này vừa thực hiện mã hóa vừa tạo Authentication Tag để kiểm tra tính toàn vẹn của dữ liệu, qua đó giúp hệ thống đảm bảo đồng thời tính bí mật và tính xác thực của thông điệp.

3.3.3 Nâng cấp cơ chế xác thực

Phiên bản Legacy sử dụng chữ ký RSA theo chuẩn PKCS#1 v1.5. Sau khi nâng cấp, hệ thống sử dụng RSA-PSS nhằm tăng khả năng chống giả mạo chữ ký và đáp ứng các khuyến nghị bảo mật hiện đại.

Ngoài ra, quá trình xác thực còn được kết hợp với Session ID để đảm bảo chữ ký chỉ có hiệu lực trong đúng phiên kết nối đã được thiết lập.

3.3.4 Nâng cấp quản lý khóa

Một trong những thay đổi quan trọng của hệ thống là cải tiến cơ chế quản lý khóa.

Ở phiên bản cũ, khóa đối xứng được sinh ngẫu nhiên và truyền trực tiếp sau khi mã hóa bằng khóa công khai RSA. Trong phiên bản nâng cấp, hệ thống sử dụng RSA-OAEP để trao đổi khóa bí mật và HKDF để dẫn xuất khóa AES-256 phục vụ cho quá trình mã hóa dữ liệu.

Cơ chế này giúp tăng tính ngẫu nhiên của khóa phiên, đồng thời hạn chế nguy cơ lộ khóa trong quá trình truyền và lưu trữ.

3.3.5 Nâng cấp cơ chế chống Replay Attack

Phiên bản Legacy chỉ sử dụng Timestamp nên chưa đủ khả năng phát hiện các gói tin được gửi lặp lại.

Trong phiên bản nâng cấp, mỗi thông điệp đều được gắn một Message ID duy nhất. Server lưu lại các Message ID đã xử lý và từ chối các gói tin có Message ID trùng lặp, từ đó ngăn chặn hiệu quả các cuộc tấn công Replay Attack.

3.3.6 Nâng cấp cơ chế ghi nhật ký

Hệ thống cũ chủ yếu ghi nhật ký trên cửa sổ dòng lệnh, gây khó khăn cho việc kiểm thử và giám sát.

Phiên bản nâng cấp bổ sung giao diện Web hiển thị nhật ký hoạt động. Các sự kiện như thiết lập kết nối, trao đổi khóa, xác thực, gửi và nhận dữ liệu cũng như các cảnh báo bảo mật đều được lưu lại, giúp việc theo dõi và đánh giá hệ thống trở nên thuận tiện hơn.

3.4 Giao diện hệ thống sau khi nâng cấp

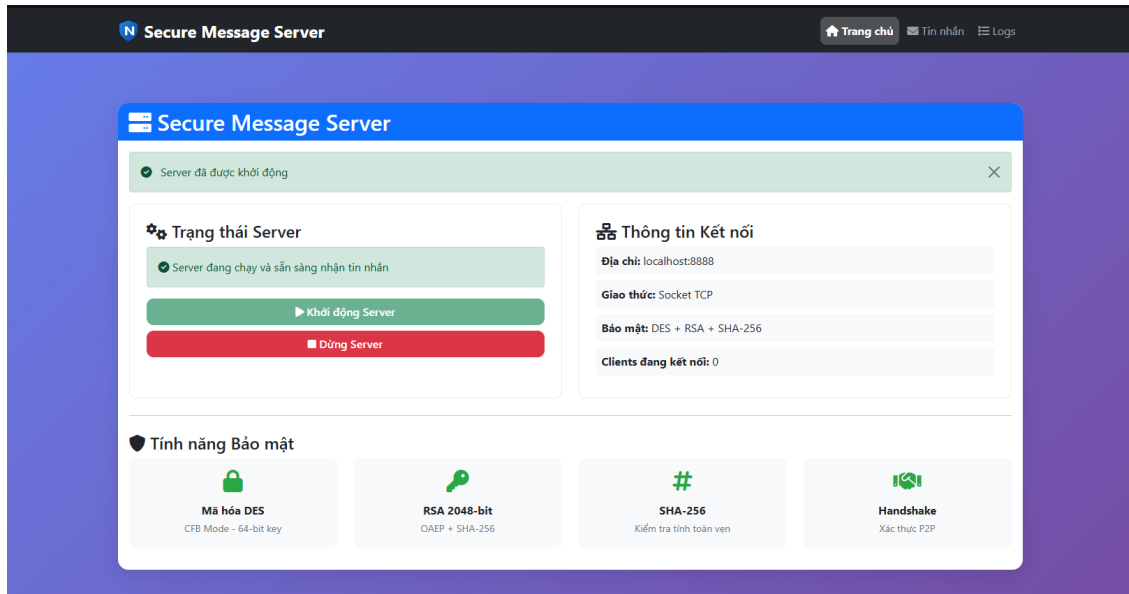
Sau khi hoàn thành quá trình nâng cấp, hệ thống Secure Message System được triển khai dưới dạng ứng dụng Web sử dụng Flask. So với phiên bản Legacy, giao diện vẫn kế thừa bố cục cũ nhằm đảm bảo tính quen thuộc đối với người sử dụng, đồng thời bổ sung thêm nhiều chức năng mới phục vụ việc quản lý phiên làm việc, giám sát quá trình truyền tin và theo dõi các sự kiện bảo mật.

Các giao diện được thiết kế theo hướng trực quan, dễ sử dụng và hỗ trợ đầy đủ các chức năng cần thiết trong quá trình gửi, nhận và quản lý tin nhắn.

3.4.1 Trang chủ hệ thống

Trang chủ là giao diện đầu tiên khi người dùng truy cập hệ thống. Từ giao diện này, người dùng có thể lựa chọn truy cập vào phía Client hoặc Server để bắt đầu quá trình thiết lập kết nối và truyền nhận dữ liệu.

Ngoài chức năng điều hướng, trang chủ còn giới thiệu tổng quan về hệ thống truyền tin bảo mật và các chức năng đã được nâng cấp.

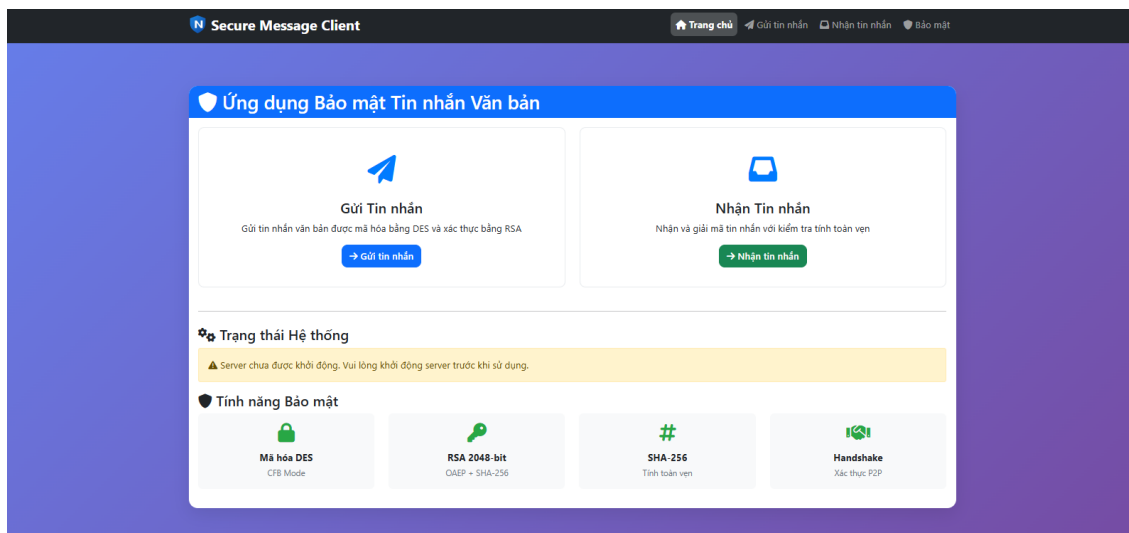


Hình 3.1. Trang chủ của hệ thống Secure Message Server

3.4.2 Giao diện Client

Giao diện Client là nơi người dùng thực hiện các thao tác kết nối đến Server, gửi thông điệp và theo dõi kết quả truyền dữ liệu.

Sau khi nâng cấp, giao diện Client được bổ sung thêm các chức năng hiển thị trạng thái kết nối, kết quả xác thực phiên làm việc và các cảnh báo bảo mật khi phát hiện lỗi trong quá trình truyền thông.

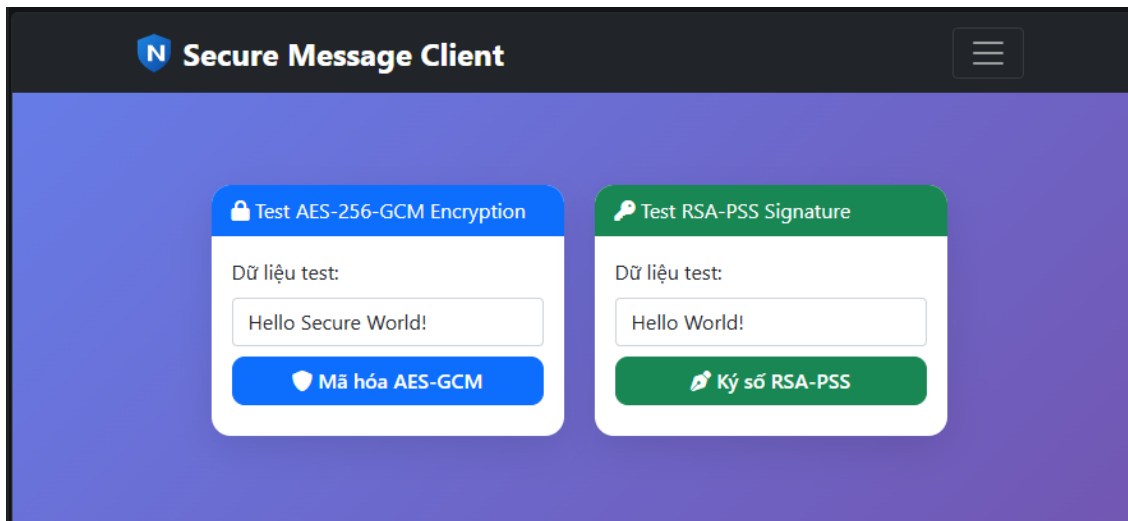


Hình 3.2. Giao diện phía Client

3.4.3 Trang bảo mật

Đây là giao diện thể hiện rõ nhất các nội dung đã được nâng cấp của hệ thống. Tại đây người dùng có thể theo dõi các thông tin liên quan đến quá trình thiết lập phiên bảo mật như thuật toán mã hóa đang sử dụng, trạng thái xác thực, Session ID, khóa phiên và các thông tin phục vụ kiểm thử.

So với phiên bản Legacy, giao diện này giúp người dùng quan sát trực tiếp toàn bộ quá trình bảo mật thay vì chỉ hiển thị kết quả trên cửa sổ dòng lệnh.



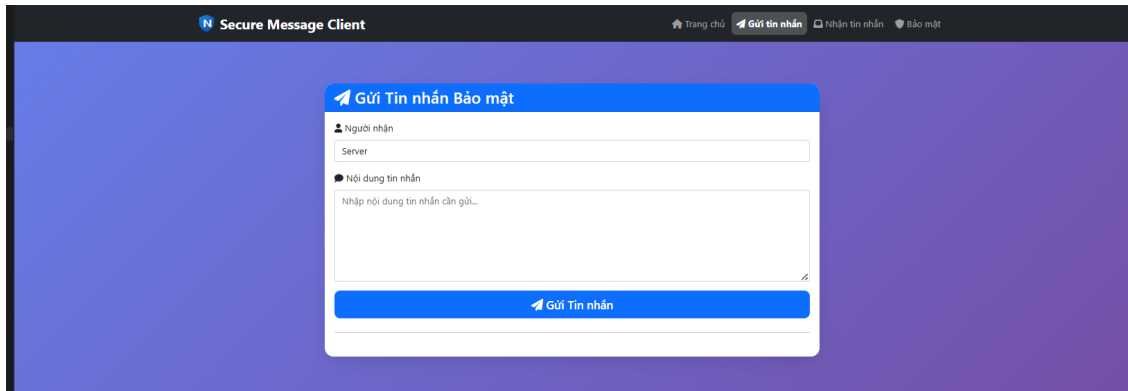
Hình 3.3. Giao diện thông tin bảo mật

3.4.4 Giao diện gửi tin nhắn

Sau khi quá trình Handshake hoàn tất và Secure Session được thiết lập, người dùng có thể nhập nội dung cần gửi.

Khi nhấn nút gửi, hệ thống sẽ tự động thực hiện các bước sinh IV ngẫu nhiên, mã hóa bằng AES-256-GCM, tạo Authentication Tag và truyền dữ liệu tới Server thông qua TCP Socket.

Nếu dữ liệu bị thay đổi hoặc chữ ký không hợp lệ, hệ thống sẽ hiển thị cảnh báo ngay trên giao diện.



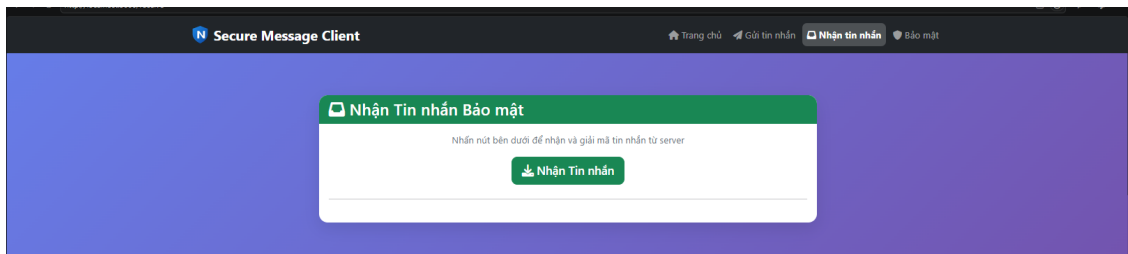
Hình 3.4. Giao diện gửi tin nhắn

3.4.5 Giao diện nhận tin nhắn

Sau khi Server tiếp nhận dữ liệu, hệ thống sẽ tiến hành kiểm tra Authentication Tag, xác thực chữ ký RSA-PSS và giải mã nội dung bằng AES-256-GCM.

Nếu toàn bộ quá trình xác thực thành công, nội dung bản rõ sẽ được hiển thị trên giao diện nhận tin nhắn.

Trong trường hợp phát hiện dữ liệu bị sửa đổi hoặc xảy ra Replay Attack, hệ thống sẽ từ chối xử lý và hiển thị cảnh báo tương ứng.

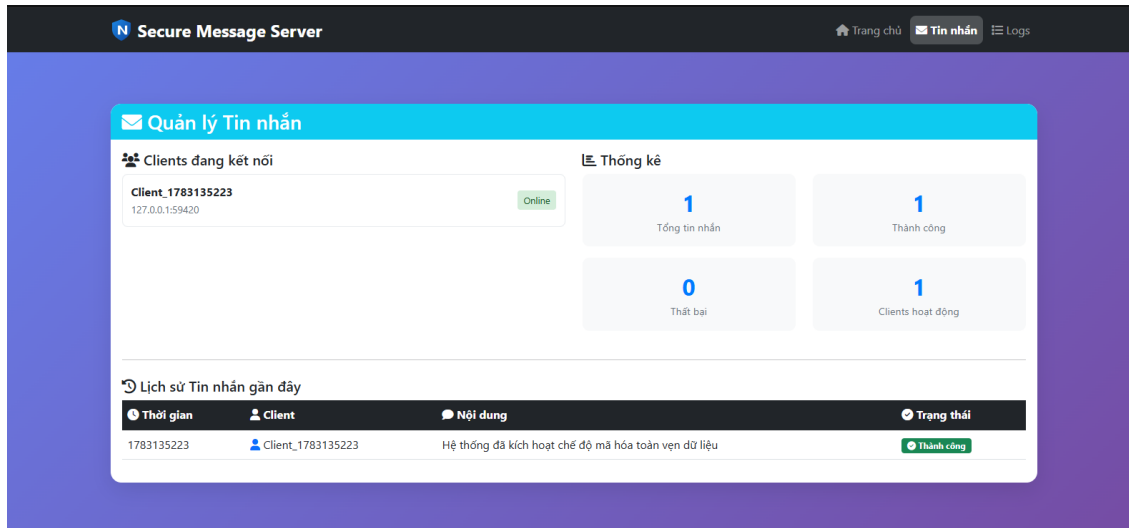


Hình 3.5. Giao diện nhận tin nhắn

3.4.6 Giao diện quản lý tin nhắn

Hệ thống bổ sung giao diện quản lý tin nhắn nhằm hỗ trợ người dùng theo dõi toàn bộ các thông điệp đã được gửi và nhận trong phiên làm việc.

Mỗi bản ghi bao gồm thời gian gửi, nội dung, trạng thái xác thực và kết quả xử lý của hệ thống. Điều này giúp người quản trị dễ dàng kiểm tra lịch sử truyền dữ liệu và hỗ trợ công tác kiểm thử.

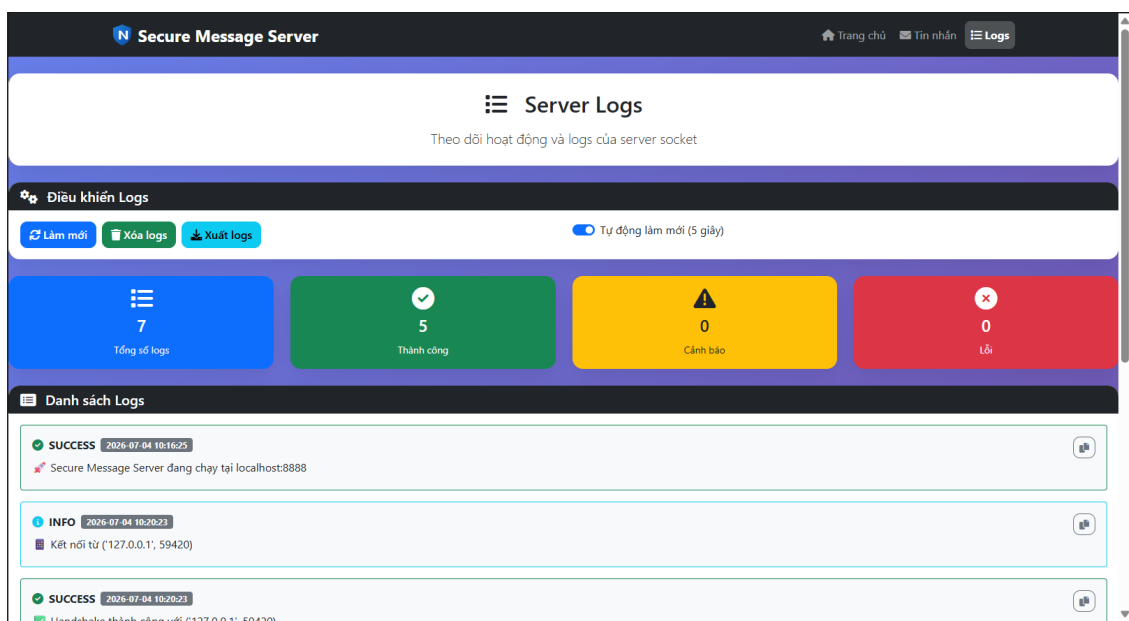


Hình 3.6. Giao diện quản lý tin nhắn

3.4.7 Giao diện nhật ký hoạt động

Một trong những nội dung được nâng cấp quan trọng của hệ thống là chức năng ghi nhật ký hoạt động.

Toàn bộ quá trình thiết lập kết nối, trao đổi khóa, xác thực, gửi và nhận dữ liệu đều được ghi lại trên giao diện Web. Ngoài ra, các sự kiện bất thường như Replay Attack, lỗi xác thực hoặc sai chữ ký số cũng được hiển thị nhằm hỗ trợ việc giám sát và đánh giá hệ thống.



Hình 3.7. Giao diện nhật ký hoạt động của hệ thống

3.5 Kết quả kiểm thử hệ thống

Sau khi hoàn thành việc triển khai, nhóm tiến hành kiểm thử toàn bộ các chức năng của hệ thống trong nhiều tình huống khác nhau nhằm đánh giá mức độ ổn định và hiệu quả của các cơ chế bảo mật đã được nâng cấp.

Quá trình kiểm thử được thực hiện trên môi trường Windows với hai ứng dụng Flask chạy độc lập ở cổng 5000 và 5001. Các trường hợp kiểm thử bao gồm thiết lập kết nối, trao đổi khóa, xác thực chữ ký số, truyền dữ liệu, phát hiện Replay Attack và ghi nhật ký hoạt động.

Kết quả cho thấy hệ thống hoạt động ổn định, các cơ chế bảo mật được triển khai đúng theo thiết kế và không xảy ra lỗi trong quá trình truyền nhận dữ liệu.

Bảng 3.2. Kết quả kiểm thử các chức năng của hệ thống

Chức năng	Kết quả	Nhận xét
Khởi động Client và Server	Đạt	Hoạt động ổn định
Thiết lập kết nối TCP	Đạt	Kết nối thành công
Trao đổi khóa RSA-OAEP	Đạt	Không xảy ra lỗi
Sinh khóa phiên HKDF	Đạt	Khóa sinh đúng yêu cầu
Xác thực RSA-PSS	Đạt	Chữ ký hợp lệ
Mã hóa AES-256-GCM	Đạt	Dữ liệu được mã hóa thành công
Giải mã AES-256-GCM	Đạt	Khôi phục đúng dữ liệu gốc
Kiểm tra Authentication Tag	Đạt	Phát hiện dữ liệu bị thay đổi
Phát hiện Replay Attack	Đạt	Từ chối gói tin lặp
Ghi nhật ký hoạt động	Đạt	Hiển thị đầy đủ trên Web

3.6 Đánh giá các cơ chế bảo mật sau khi nâng cấp

Sau khi hoàn thành việc triển khai và kiểm thử, nhóm tiến hành đánh giá hiệu quả của các cơ chế bảo mật đã được tích hợp trong hệ thống. Kết quả cho thấy phiên bản nâng cấp không chỉ kế thừa được những chức năng của hệ thống Legacy mà còn cải thiện đáng kể khả năng bảo vệ dữ liệu trong quá trình truyền thông.

3.6.1 Đánh giá thuật toán mã hóa

Ở hệ thống Legacy, dữ liệu được mã hóa bằng thuật toán DES hoặc Triple DES. Đây là các thuật toán đã tồn tại từ lâu và hiện nay không còn đáp ứng được yêu cầu bảo mật trước các phương pháp tấn công hiện đại.

Phiên bản nâng cấp đã thay thế hoàn toàn DES bằng thuật toán AES-256-GCM. Thuật toán này vừa thực hiện chức năng mã hóa dữ liệu vừa tích hợp cơ chế xác thực thông qua Authentication Tag. Nhờ đó, hệ thống không chỉ đảm bảo tính bí mật của dữ liệu mà còn có khả năng phát hiện các trường hợp dữ liệu bị thay đổi trong quá trình truyền.

3.6.2 Đánh giá cơ chế trao đổi khóa

Hệ thống Legacy chỉ sử dụng RSA để mã hóa khóa phiên mà chưa tối ưu về mặt bảo mật.

Trong phiên bản mới, nhóm sử dụng RSA-OAEP để trao đổi khóa bí mật. Đây là chuẩn được khuyến nghị sử dụng trong các hệ thống hiện đại do có khả năng chống lại nhiều hình thức tấn công vào quá trình trao đổi khóa.

Sau khi nhận được khóa bí mật, hai bên tiếp tục sử dụng HKDF để dẫn xuất khóa phiên AES-256 phục vụ cho việc mã hóa dữ liệu.

3.6.3 Đánh giá cơ chế xác thực

Phiên bản cũ sử dụng chữ ký số RSA theo chuẩn PKCS#1 v1.5.

Phiên bản nâng cấp chuyển sang sử dụng RSA-PSS nhằm tăng mức độ an toàn cho chữ ký số. Đồng thời, chữ ký còn được kết hợp với Session ID để đảm bảo chỉ những thông điệp thuộc đúng phiên làm việc mới được chấp nhận.

Việc xác thực giúp ngăn chặn các trường hợp giả mạo người gửi hoặc thay đổi nội dung thông điệp.

3.6.4 Đánh giá cơ chế kiểm tra toàn vẹn

Thay vì sử dụng hàm băm SHA-256 độc lập như trước đây, hệ thống mới sử dụng trực tiếp Authentication Tag được tạo bởi AES-256-GCM.

Khi Server nhận dữ liệu, Authentication Tag sẽ được kiểm tra trước khi tiến hành giải mã. Nếu dữ liệu bị thay đổi trong quá trình truyền, hệ thống sẽ từ chối xử lý và thông báo lỗi đến người dùng.

Nhờ đó, hệ thống đảm bảo được tính toàn vẹn của dữ liệu truyền trên mạng.

3.6.5 Đánh giá cơ chế chống Replay Attack

Phiên bản Legacy chỉ sử dụng Timestamp nên chưa đủ khả năng phát hiện các gói tin được gửi lặp lại.

Sau khi nâng cấp, mỗi thông điệp đều được gắn một Message ID duy nhất. Server lưu danh sách các Message ID đã xử lý và từ chối các gói tin có Message ID trùng lặp.

Cơ chế này giúp hệ thống phát hiện và ngăn chặn hiệu quả các cuộc tấn công Replay Attack.

3.6.6 Đánh giá cơ chế ghi nhật ký

Hệ thống mới bổ sung giao diện nhật ký hoạt động trên nền Web.

Toàn bộ các sự kiện như khởi tạo kết nối, thiết lập phiên làm việc, trao đổi khóa, xác thực, gửi và nhận dữ liệu đều được ghi lại.

Các cảnh báo bảo mật như sai chữ ký số, Replay Attack hoặc lỗi giải mã cũng được hiển thị trên giao diện giúp người quản trị dễ dàng theo dõi hoạt động của hệ thống.

3.7 So sánh hệ thống Legacy và hệ thống sau nâng cấp

Bảng 3.3. So sánh giữa hệ thống Legacy và hệ thống sau nâng cấp

Tiêu chí	Hệ thống Legacy	Hệ thống nâng cấp
Thuật toán mã hóa tích hợp Authentication Tag	DES/3DES	AES-256-GCM
Trao đổi khóa kết hợp HKDF	RSA cơ bản	RSA-OAEP
Xác thực kết hợp Session ID	RSA PKCS#1 v1.5	RSA-PSS
Kiểm tra toàn vẹn của AES-GCM	SHA-256	Authentication Tag
Quản lý khóa khóa phiên AES-256	Khóa sinh ngẫu nhiên	HKDF dẫn xuất
Replay Attack và danh sách kiểm tra	Timestamp	Message ID (Nonce)
Nhật ký hệ thống	Console	Web Logs và Console Logs
Giao diện	Flask cơ bản	Flask tích hợp quản lý bảo mật và nhật ký
Mức độ bảo mật	Trung bình	Cao

3.8 Đánh giá chung

Kết quả triển khai và kiểm thử cho thấy hệ thống hoạt động ổn định trên môi trường thử nghiệm. Các chức năng chính như thiết lập kết nối TCP, trao đổi khóa, xác thực chữ ký số, mã hóa và giải mã dữ liệu, phát hiện Replay Attack và ghi nhật ký hoạt động đều được thực hiện thành công.

So với hệ thống Legacy, phiên bản nâng cấp vẫn giữ nguyên kiến trúc Client–Server

và giao diện Flask nhằm đảm bảo khả năng kế thừa. Tuy nhiên, các cơ chế bảo mật bên trong đã được thay thế bằng các thuật toán hiện đại hơn, giúp tăng đáng kể mức độ an toàn của dữ liệu trong quá trình truyền thông.

Việc kết hợp các thuật toán AES-256-GCM, RSA-OAEP, RSA-PSS và HKDF cùng với cơ chế Authentication Tag và Message ID đã nâng cao đáng kể mức độ an toàn của hệ thống.

Nhờ đó, hệ thống đáp ứng tốt các yêu cầu về tính bí mật, tính toàn vẹn, tính xác thực và khả năng chống phát lại dữ liệu trong quá trình truyền thông.

3.9 Kết luận chương

Trong chương này, nhóm đã trình bày quá trình triển khai và đánh giá hệ thống Secure Message Server sau khi nâng cấp từ phiên bản Legacy. Hệ thống được xây dựng theo mô hình Client–Server, sử dụng Flask để phát triển giao diện Web và TCP Socket để truyền dữ liệu.

Các kết quả kiểm thử cho thấy hệ thống hoạt động ổn định và thực hiện thành công các chức năng bảo mật như trao đổi khóa RSA-OAEP, sinh khóa phiên bằng HKDF, xác thực bằng RSA-PSS, mã hóa dữ liệu bằng AES-256-GCM, kiểm tra Authentication Tag, phát hiện Replay Attack và ghi nhật ký hoạt động.

Việc kế thừa kiến trúc cũ kết hợp với các cơ chế bảo mật hiện đại đã giúp nâng cao đáng kể mức độ an toàn của hệ thống mà không làm thay đổi cấu trúc tổng thể của chương trình. Đây cũng là cơ sở để tiếp tục mở rộng hệ thống trong tương lai như bổ sung xác thực đa yếu tố, chứng thư số hoặc triển khai trên môi trường Internet thực tế.

KẾT LUẬN

Sau quá trình nghiên cứu, phân tích và triển khai, nhóm đã hoàn thành việc nâng cấp hệ thống truyền tin bảo mật (Secure Message System) theo đúng mục tiêu đã đề ra. Hệ thống được xây dựng dựa trên mô hình Client–Server, sử dụng giao thức TCP Socket kết hợp với giao diện Web được phát triển bằng Flask.

Trong quá trình thực hiện, nhóm đã kế thừa kiến trúc của hệ thống Legacy, đồng thời thay thế và bổ sung nhiều cơ chế bảo mật hiện đại nhằm nâng cao mức độ an toàn trong quá trình truyền dữ liệu. Cụ thể, thuật toán DES đã được thay thế bằng AES-256-GCM; cơ chế trao đổi khóa sử dụng RSA-OAEP; chữ ký số được nâng cấp từ RSA PKCS#1 v1.5 lên RSA-PSS; khóa phiên được dẫn xuất bằng HKDF; đồng thời bổ sung Authentication Tag để kiểm tra tính toàn vẹn của dữ liệu và cơ chế Message ID nhằm phát hiện các cuộc tấn công Replay Attack.

Bên cạnh việc nâng cấp các thuật toán bảo mật, nhóm cũng cải tiến giao diện hệ thống bằng cách bổ sung các chức năng quản lý tin nhắn, hiển thị trạng thái xác thực, ghi nhật ký hoạt động và cảnh báo các sự kiện bất thường ngay trên giao diện Web. Điều này giúp người sử dụng dễ dàng theo dõi trạng thái hoạt động của hệ thống và hỗ trợ quá trình kiểm thử.

Kết quả kiểm thử cho thấy hệ thống hoạt động ổn định, quá trình thiết lập kết nối, trao đổi khóa, xác thực, mã hóa và giải mã dữ liệu đều được thực hiện thành công. Các cơ chế bảo mật được triển khai đã đáp ứng các yêu cầu về tính bí mật, tính toàn vẹn, tính xác thực và khả năng chống phát lại dữ liệu trong quá trình truyền thông.

Mặc dù đã đạt được các mục tiêu chính của đề tài, hệ thống vẫn còn một số hạn chế. Chương trình hiện mới được triển khai trong môi trường mạng cục bộ, chưa tích hợp cơ chế quản lý chứng thư số (Certificate), chưa hỗ trợ xác thực đa yếu tố và chưa triển khai trên môi trường Internet thực tế.

Trong thời gian tới, nhóm dự kiến sẽ tiếp tục phát triển hệ thống theo các hướng sau:

- Tích hợp hạ tầng khóa công khai (PKI) và chứng thư số.
- Hỗ trợ xác thực đa yếu tố (Multi-Factor Authentication).
- Xây dựng cơ chế quản lý người dùng và phân quyền truy cập.
- Lưu trữ lịch sử truyền tin trên cơ sở dữ liệu.
- Triển khai hệ thống trên máy chủ Cloud hoặc VPS.

- Tối ưu hiệu năng và khả năng mở rộng khi nhiều Client kết nối đồng thời.

Nhìn chung, đề tài đã giúp nhóm vận dụng được các kiến thức về an toàn và bảo mật thông tin, lập trình mạng, mật mã học và phát triển ứng dụng Web vào một hệ thống thực tế. Đây cũng là nền tảng quan trọng để tiếp tục nghiên cứu các hệ thống truyền thông an toàn trong tương lai.

PHỤ LỤC

Phụ lục A. Cấu trúc thư mục dự án

Hệ thống được xây dựng theo mô hình Client–Server và được tổ chức theo cấu trúc thư mục như sau:

```
Secure-System-Upgrade
|
|-- client_app.py
|-- server_app.py
|-- socket_client.py
|-- socket_server.py
|-- crypto_utils.py
|-- run_both.py
|-- test_security.py
|
|-- templates/
|   |-- client_index.html
|   |-- client_send.html
|   |-- client_receive.html
|   |-- client_security.html
|   |-- server_index.html
|   |-- server_logs.html
|   `-- server_messages.html
|
|-- static/
|   |-- style.css
|   |-- script.js
|   `-- logo.svg
|
|-- requirements.txt
`-- README.md
```

Cấu trúc trên giúp chương trình được tổ chức rõ ràng, thuận tiện cho việc bảo trì, mở rộng và triển khai hệ thống.

Phụ lục B. Danh sách các thư viện sử dụng

Hệ thống sử dụng các thư viện chính sau:

- Flask: Xây dựng giao diện Web và API.
- Cryptography: Triển khai các thuật toán mã hóa và chữ ký số.
- Socket: Thiết lập kết nối TCP giữa Client và Server.
- JSON: Trao đổi dữ liệu giữa hai phía.
- Logging: Ghi nhật ký hoạt động của hệ thống.
- Hashlib: Hỗ trợ xử lý hàm băm.
- Secrets: Sinh số ngẫu nhiên phục vụ bảo mật.
- Threading: Xử lý đa luồng.
- OS: Thao tác với hệ điều hành.

Phụ lục C. Các thuật toán bảo mật được sử dụng

Phiên bản nâng cấp của hệ thống sử dụng các thuật toán và cơ chế bảo mật sau:

- AES-256-GCM.
- RSA-OAEP.
- RSA-PSS.
- HKDF.
- SHA-256.
- Authentication Tag.
- Message ID (Nonce).
- Replay Attack Detection.

Các thuật toán trên giúp hệ thống đảm bảo tính bí mật, tính toàn vẹn, tính xác thực và khả năng chống tấn công phát lại trong quá trình truyền dữ liệu.

Phụ lục D. Các giao diện của hệ thống

Các giao diện chính của chương trình đã được trình bày và minh họa trong Chương 3 của báo cáo, bao gồm:

- Trang chủ của hệ thống.
- Trang Client.
- Trang bảo mật.
- Trang gửi tin nhắn.
- Trang nhận tin nhắn.
- Trang quản lý tin nhắn.
- Trang nhật ký hoạt động (Logs).

Các giao diện được xây dựng bằng Flask kết hợp HTML, CSS và JavaScript, hỗ trợ người dùng thao tác trực quan và theo dõi trạng thái hoạt động của hệ thống.

Phụ lục E. Tài liệu, mã nguồn hoặc liên kết liên quan

Toàn bộ mã nguồn của đề tài được lưu trữ trong thư mục **Secure-System-Upgrade**. Dự án bao gồm đầy đủ mã nguồn phía Client, phía Server, các mô-đun xử lý bảo mật, giao diện Web và các tệp cấu hình cần thiết để triển khai hệ thống.

Các tệp mã nguồn chính gồm:

- `client_app.py`: Giao diện và xử lý phía Client.
- `server_app.py`: Giao diện và xử lý phía Server.
- `socket_client.py`: Thiết lập và quản lý kết nối TCP phía Client.
- `socket_server.py`: Thiết lập và quản lý kết nối TCP phía Server.
- `crypto_utils.py`: Cài đặt các thuật toán AES-256-GCM, RSA-OAEP, RSA-PSS, HKDF và cơ chế kiểm tra Authentication Tag.
- `run_both.py`: Khởi động đồng thời ứng dụng Client và Server.
- `test_security.py`: Kiểm thử các chức năng bảo mật của hệ thống.

- `templates/`: Chứa các tệp HTML xây dựng giao diện Web.
- `static/`: Chứa các tệp CSS, JavaScript và hình ảnh của hệ thống.
- `requirements.txt`: Danh sách các thư viện Python cần cài đặt.
- `README.md`: Hướng dẫn cài đặt, cấu hình và sử dụng chương trình.

Toàn bộ mã nguồn được nộp kèm theo báo cáo để phục vụ việc kiểm tra, đánh giá và triển khai hệ thống.

TÀI LIỆU THAM KHẢO

- [1] Python Software Foundation, *Python Documentation*, <https://docs.python.org/>
- [2] Pallets Projects, *Flask Documentation*, <https://flask.palletsprojects.com/>
- [3] PyCA Developers, *Cryptography Documentation*, <https://cryptography.io/>
- [4] National Institute of Standards and Technology (NIST), *Advanced Encryption Standard (AES)*, FIPS PUB 197, 2001.
- [5] National Institute of Standards and Technology (NIST), *Recommendation for Block Cipher Modes of Operation: GCM and GMAC*, NIST SP 800-38D, 2007.
- [6] Moriarty, K., Kaliski, B., Jonsson, J., Rusch, A., *PKCS #1: RSA Cryptography Specifications Version 2.2*, RFC 8017, Internet Engineering Task Force (IETF), 2016.